

บทที่ 4

สเตตฟูลไฟร์วอลล์

Stateful Firewall

4.1 หลักการทำงานของสเตตฟูลไฟร์วอลล์

การทำงานของสเตตฟูลอินสเปกชัน จะมีการติดตามสถานะ (State) การทำงานของการเชื่อมต่อแบบ TCP ซึ่งเป็นผลให้สามารถดูรูปแบบการทำงานได้ทั้งกระบวนการ ไม่ได้ดูเพียงข้อมูลในแต่ละแพ็กเก็ต โดยสามารถดูลักษณะการเชื่อมต่อ การโต้ตอบของแต่ละโปรโตคอลที่มีลักษณะที่แตกต่างกัน โดยสามารถแยกแยะโปรโตคอลที่ถูกต้องกับโปรโตคอลที่ไม่ถูกต้องออกจากกันได้

โดยทั่วไปมักจะแยกกันโดยชัดเจนระหว่างไฟร์วอลล์แบบ Stateful filtering และระบบ application level proxy server ในบทนี้เราจะไม่กล่าวถึงหลักการทำงานของแอปพลิเคชันพร็อกซี (Application Proxies) ซึ่งอยู่นอกขอบเขตที่ศึกษา

4.2 การแบ่งชนิดไฟร์วอลล์

4.2.1 แพ็กเก็ตฟิลเตอร์ริง (Packet Filtering)

ไฟร์วอลล์ชนิดนี้จะกรองแพ็กเก็ตโดยพิจารณาแพ็กเก็ตที่เข้าออกตามกฎที่ตั้งไว้ การตัดสินใจกรองแพ็กเก็ตเหล่านี้จะยึดข้อมูลที่อยู่ในเฮดเดอร์ของแพ็กเก็ตตัวนั้นๆ เช่น แอดเดรสต้นทาง แอดเดรสปลายทาง พอร์ตหรือโปรโตคอล ผลัดกันที่ไฟร์วอลล์บางตัวที่สามารถกรองแพ็กเก็ต ยังมีความสามารถในการกรองข้อมูลในส่วนอื่นที่ไม่ใช่แพ็กเก็ตเฮดเดอร์ด้วย เมื่อแพ็กเก็ตแต่ละแพ็กเก็ตเข้ามาสู่ไฟร์วอลล์จะนำมาเทียบกับกฎ หากเข้ากับกฎใดกฎหนึ่งจะถือว่ากฎนั้นสั่งให้ส่งแพ็กเก็ตนั้นต่อไป หรือครีอปแพ็กเก็ตนั้นทิ้งไป และหากไม่เข้ากับกฎใดเลย ก็จะพิจารณาว่าค่าเริ่มต้นเป็นอะไร ให้ส่งหรือครีอปแพ็กเก็ตทิ้งไป

A

Action	Out host	Port	Their host	Port	Comment
Block	*	*	SPIGOT	*	We don't trust these people
Allow	OUR_GW	25	*	*	Connection to our people

B

Action	Out host	Port	Their host	Port	Comment
Block	*	*	*	*	Default

C

Action	Out host	Port	Their host	Port	Comment
Allow	*	*	*	25	Connection to their SMTP port

D

Action	Out host	Port	Their host	Port	Comment
Allow	{ Our host }	*	*	25	Our packets to their SMTP port
Allow	*	25	*	*	Their replies

E

Action	Out host	Port	Their host	Port	Comment
Allow	{ Our host }	*	*	*	Our outgoing calls
Block	*	*	SPIGOT	*	Replies to our calls
Allow	OUR_GW	25	*	*	Traffic to nonservers

ตารางที่ 4-1 แสดงตัวอย่างกฎที่ตั้งไว้สำหรับไฟร์วอลล์แบบแพ็กเก็ตฟิลเตอร์

ตารางข้างบนนี้ แสดงตัวอย่างของกฎที่ตั้งไว้สำหรับไฟร์วอลล์แบบแพ็กเก็ตฟิลเตอร์ (Packet Filtering) โดยนำกฎมาใช้จะทำจากข้างบนลงมาถึงล่าง โดยในตาราง A นั้นมีการสร้างบล็อกเครื่องที่ชื่อ SPIGOT โดยจะปล่อย SMTP แต่จะต้องไปยังเครื่อง OUR-GW เท่านั้น ในตาราง B เป็นค่า Default ซึ่งจะถูกพิจารณาสุดท้าย ตาราง C จะยอมให้ข้อมูลที่มีพอร์ตปลายทางเป็น SMTP ผ่านไปได้ ซึ่งกรณีนี้ยังมีจุดอ่อน คือ สามารถโจมตีผ่านพอร์ต 25 ได้ ตาราง D จะยอมให้เฉพาะเครื่องที่อยู่ในลิสต์ที่มี SYN เท่านั้น ซึ่งจะทำให้ไม่สามารถโจมตีที่พอร์ต 25 ได้ ตาราง E จะยอมให้เฉพาะเครื่องที่อยู่ในลิสต์เท่านั้นที่ออกได้ และจะรับแพ็กเก็ตที่มี SYN หรือมีพอร์ตมากกว่า 1024 เท่านั้น

การตัดสินใจในกรองแพ็กเก็ต โดยยึดข้อมูลที่อยู่ในแพ็กเก็ตเฮดเดอร์ (Packet Header) ของแพ็กเก็ตตัวนั้นๆ เช่น แอดเดรสต้นทาง (Source Address) แอดเดรสปลายทาง (Destination Address) พอร์ต (Port) โพรโตคอล (Protocol) ผลัดกันที่ไฟร์วอลล์บางตัวที่สามารถกรองแพ็กเก็ต ยังมีความสามารถในการกรองข้อมูลในส่วนอื่นที่ไม่ใช่แพ็กเก็ตเฮดเดอร์ แต่เราจะพิจารณาส่วนนี้ในหัวข้อของ stateful inspection packet filter

4.2.2 แอปพลิเคชันพร็อกซี (Application Proxies)

แอปพลิเคชันพร็อกซีเป็นโปรแกรมแอปพลิเคชันที่รันอยู่บนระบบไฟร์วอลล์ระหว่างสองเครือข่าย โดยเครื่องที่รันพร็อกซีไม่ต้องทำตัวเป็นเราเตอร์เมื่อโปรแกรมจากเครื่องไคลเอนต์เริ่มการติดต่อผ่านพร็อกซีไปยังเครื่องที่ให้บริการปลายทาง เริ่มแรกต้องทำการติดต่อกับโปรแกรมพร็อกซีเซิร์ฟเวอร์ก่อน โดยตัวไคลเอนต์จะทำการเจรจาด้วยพร็อกซีให้ทำการติดต่อกับเครื่องที่ให้บริการปลายทางให้ ถ้าเป็นผลสำเร็จจะ

เกิดการเชื่อมต่อ 2 การเชื่อมต่อ คือ ระหว่างเครื่องไคลเอนต์กับเครื่องพร็อกซีเซิร์ฟเวอร์ และระหว่างเครื่องพร็อกซีกับเครื่องให้บริการปลายทาง เราจะเห็นได้ว่าพร็อกซีจะรับภาระของการจราจรทางระหว่างเครื่องไคลเอนต์กับเครื่องพร็อกซีเซิร์ฟเวอร์ จะทำการสร้างการติดต่อทั้งหมดและทำหน้าที่ในการตัดสินใจในการทำฟอร์เวิร์ดแพ็กเก็ตด้วย โดยพร็อกซีนี้นี้ไม่มีส่วนเกี่ยวข้องในส่วนของการหาเส้นทาง

ทำนองเดียวกันกับแพ็กเก็ตไฟลเตอร์ริง ในแอปพลิเคชันพร็อกซีนี้นั้นก็สามารถทำงานได้ในสองแพลตฟอร์ม คือ อุปกรณ์ที่ทำหน้าที่เป็นพร็อกซีโดยเฉพาะ กับคอมพิวเตอร์ที่ใช้ในงานทั่วไป ซึ่งโดยทั่วไปแล้วแอปพลิเคชันพร็อกซีจะช้ากว่าเราเตอร์ที่ใช้กรองแพ็กเก็ต แต่ในขณะเดียวกันแอปพลิเคชันพร็อกซีมีความปลอดภัยสูงกว่าแพ็กเก็ตไฟลเตอร์ริง โดยที่จริงแพ็กเก็ตไฟลเตอร์ริงสามารถทนรับข้อบกพร่องจากการโจมตีได้ หรือทดแทนในส่วนของการโจมตีที่เรเตอร์ของเราดของระบบปฏิบัติการ แต่เมื่อความสามารถของแพ็กเก็ตไฟลเตอร์ริงถูกเพิ่มเข้าไปในการหาเส้นทาง มันก็ไม่สามารถที่จะชดเชยหรือทำให้ข้อบกพร่องในการหาเส้นทางถูกต้องได้

ผลจากการทำการกรองที่ซับซ้อนขึ้นและการตัดสินใจในการควบคุมการเข้าถึงแอปพลิเคชันพร็อกซีสามารถใช้ทรัพยากรคอมพิวเตอร์ที่สำคัญ และเครื่องราคาแพงที่ใช้ในการปฏิบัติงาน ตัวอย่างเช่น ถ้าไฟร์วอลล์ทำงานบนระบบยูนิกซ์ ต้องการที่จะให้การสนับสนุนการทำงานจำนวน 200 HTTP session ที่ทำงานพร้อมๆกัน เครื่องที่ใช้ต้องมีความสามารถในการสนับสนุนงานของ 200 HTTP proxy ด้วยในแง่ของประสิทธิภาพในการรับ / ส่งข้อมูล และเมื่อเพิ่มอีก 100 FTP session , 25 SMTP session, LDAP session ส่วนหนึ่ง และ DNS transaction คุณจะต้องใช้เครื่องที่สนับสนุน 500-1000 proxy process บางพร็อกซีอาจจะอิมพลีเมนต์โดยใช้ kernel threads (เพื่อช่วยลดความต้องการของทรัพยากรลงอย่างรวดเร็ว) แต่ความต้องการในทรัพยากรก็ยังคงมากอยู่ดี

4.2.3 สเตตฟูลอินสเปกชัน (Stateful Inspection) หรือ ไดนามิกแพ็กเก็ตไฟลเตอร์ริง (Dynamic packet filtering)

เราใช้คำว่า “ สเตตฟูลอินสเปกชัน “ หรือ “ ไดนามิกแพ็กเก็ตไฟลเตอร์ริง “ หมายถึง เซตฟังก์ชันที่ทำการกรองแพ็กเก็ตที่มีความสามารถขึ้นในเราเตอร์ โดยที่แพ็กเก็ตไฟลเตอร์ริงถูกจำกัดอยู่ในการตัดสินใจ โดยข้อมูลในการตัดสินใจจะอยู่ในส่วนของเฮดเดอร์เท่านั้น และจะพิจารณาเฉพาะแพ็กเก็ตตัวนั้นๆ เท่านั้น โดยไม่ได้คำนึงถึงแพ็กเก็ตก่อนหน้านี้ ส่วนสเตตฟูลอินสเปกชันจะเอาชนะข้อจำกัดนี้ของแพ็กเก็ตไฟลเตอร์ริงทั้งในส่วนข้อมูลที่ใช้ในการตัดสินใจ โดยจะดูถึงข้อมูลในส่วนของเมสเสจด้วยและจะคำนึงถึงในส่วนของแพ็กเก็ตอื่นๆ ที่อยู่ก่อนหน้านี้ประกอบในการตัดสินใจ ทำให้ความสามารถในการตัดสินใจมีมากขึ้น เพราะรู้ข้อมูลมากขึ้น ซึ่งสเตตฟูลอินสเปกชันก็เหมือนกับแพ็กเก็ตไฟลเตอร์ริง คือ อิมพลีเมนต์เพิ่มลงในเราเตอร์ ดังนั้นโฮสต์ที่มีฟังก์ชันของสเตตฟูลอินสเปกชันทำงานอยู่นั้นจะต้องเป็นหรือสามารถทำงานเสมือนเราเตอร์ได้ด้วย

เจตนาพื้นฐานของสเตตฟูลอินสเปกชัน นั้นเพื่อรวมข้อดีระหว่างประสิทธิภาพในแง่ของการส่งถ่ายข้อมูลและความปลอดภัย โดยเพิ่มการทำงานลงในเราเตอร์ทำให้สเตตฟูลอินสเปกชันมีประสิทธิภาพในการส่งถ่ายข้อมูลดีกว่าพร็อกซี และยังมีการเพิ่มระดับฟังก์ชันของไฟร์วอลล์ให้ดีกว่าแพ็กเก็ตไฟลเตอร์ริง

ธรรมดา และสเตตฟูลอินสเปกชันยังมีส่วนคล้ายกับฟร็อกซี คือ เกณฑ์ของการควบคุมการเข้าถึงข้อมูลที่ซับซ้อนสามารถระบุรายละเอียดได้ และเหมือนกับแพ็กเก็ตไฟลเตอร์ริง คือ สเตตฟูลอินสเปกชันได้รับการสืบทอดมาจากการอิมพลิเมนต์การหาเส้นทางที่มีคุณภาพสูง

4.3 หลักการทำงานของซิมเพิลแพ็กเก็ตไฟลเตอร์ (Simple Packet Filter)

ซันโอไฟเลเยอร์ นั้นเป็นชั้นที่ทั้งซิมเพิลแพ็กเก็ตไฟลเตอร์ (simple packet filter) และ สเตตฟูลไฟลเตอร์ (stateful filter) ใช้เป็นจุดเริ่มต้นในการพิจารณาข้อมูล สิ่งที่ซิมเพิลแพ็กเก็ตไฟลเตอร์และสเตตฟูลไฟร์วอลล์ ทำเหมือนกันก็คือ ตรวจสอบข้อมูล header ของไอพีแพ็กเก็ตโดยสิ่งที่ถูกตรวจสอบ คือ source address, destination address, protocol , options

นโยบายของไฟร์วอลล์ส่วนใหญ่มักจะตรวจสอบความถูกต้องของแอดเดรส (ทั้ง source address และ destination address) ด้วย ยกเว้นกรณีที่จะระบุเป็น “all” และข้อมูลในส่วนของโพรโทคอลนั้นก็จะเป็นตัวบอกว่าส่วนของค่านั้นบรรจุข้อมูลชนิดใดอยู่ เช่น TCP, UDP หรือบางทีอาจจะเป็น IPSEC, ESP, ISAKMP กระบวนการในการตรวจสอบรูปแบบของเฮดเดอร์นั้นจะอยู่ที่เลเยอร์ชั้นบนถัดไป และข้อมูลในส่วนอปชันนั้น โดยปกติมักจะไม่มีค่าอะไร แต่อาจจะมีแฟล็ก (flag) ที่แสดงถึง ซอร์ทเร้าต์ติง (source routing) ได้ (source routing ใช้ในกรณีที่ผู้ส่งต้องการให้ผู้รับส่งข้อมูลผ่านเส้นทางที่ผู้ส่งได้กำหนดไว้) โดยปกติแล้วมักจะถูกใช้โดยผู้บุกรุก ดังนั้นซิมเพิลแพ็กเก็ตไฟลเตอร์ส่วนใหญ่จะคัดลอกแพ็กเก็ตที่ถูกส่งมาพร้อมกับแฟล็กดังกล่าว โดยไม่มีการตรวจสอบข้อมูลอย่างอื่นเพิ่มเติม

ทีซีพีเฮดเดอร์ บรรจุข้อมูล 3 ส่วนที่สำคัญในทรานสปอร์ตเลเยอร์ (transport layer) ไว้คือ source port , destination port และ แฟล็ก โดยในส่วนของแฟล็กนั้น สามารถประกอบไปด้วย URG (urgent), ACK (acknowledgment), PSH (push), RST (reset), SYN (synchronize) และ FIN (finish) และยังมีส่วนที่สี่ที่บรรจุ sequence number ซึ่งผู้ผลิตบางค่ายนำมาใช้พิจารณาด้วย

สำหรับแฟล็กนั้นเป็นส่วนสำคัญมากในสเตตฟูลไฟร์วอลล์ เช่น การทำ ทีซีพี ทรี่เวย์แฮนด์เชค (TCP – 3 way handshake

Source			Destination		
Sequence					
Acknowledgment					
	Reserv	Fla	Window		
Checks			Urgent		
Optio				Paddi	

รูปที่ 4-1 TCP header

ยูติพี เฮดเดอร์ บรรจุข้อมูลเพียงแค่ source port และ destination port เท่านั้นเอง ไม่มีส่วนของแฟล็ก และ ซีเควนซ์เบอร์ (sequence number) แต่อย่างใด เนื่องจาก ยูติพีเป็น connectionless protocol อยู่แล้วนั่นเอง ไม่ได้บรรจุข้อมูลพอร์ตแต่อย่างใด แต่บรรจุชนิดของ ไอซีเอ็มพี (ICMP message type) เช่น “Echo request” , “Destination Unreachable”

Source	Destination
Length	Checksum
Data begin here	

รูปที่ 4-2 UDP header

ซิมเพิลแพ็กเก็ตฟิลเตอร์ (Simple packet filter) จะพิจารณา ทีซีพีแพ็กเก็ตเพื่อตรวจสอบว่า

- แพ็กเก็ตนั้นมีแอคเรสที่ถูกต้องหรือไม่
- แพ็กเก็ตนั้นถูกสร้างมาจาก External address จริงหรือไม่
- โพรโทคอล หรือ เซอร์วิสนั้น ผ่านการตรวจสอบแล้วหรือไม่
- ออปชั่น หรือ แฟล็กที่ส่งมานั้น ถูกต้องตามข้อกำหนดหรือไม่

ในกรณีที่มีการส่ง ACK แพ็กเก็ตดังกล่าวถูกส่งมาโดยเจตนาร้าย เพราะเมื่อเครื่องปลายทางได้รับ ACK มักจะส่งสัญญาณ RST กลับไป ซึ่งจะแสดงให้เห็นว่าเครื่องปลายทางนั้นยังเปิดอยู่ และเปิดให้บริการในพอร์ตดังกล่าว (destination port ที่ส่งมาพร้อมกับ ACK packet) บางครั้งยังสามารถใช้ตรวจสอบระบบปฏิบัติการของเครื่องปลายทางได้อีกด้วย (OS fingerprint) เพราะระบบปฏิบัติการในแต่ละระบบนั้น มักมีวิธีตอบกลับที่แตกต่างกันออกไป

4.4 หลักการทำงานของแพ็กเก็ตฟิลเตอร์ริงสเตตฟูลไฟร์วอลล์(Packet – filtering stateful firewall)

สำหรับแพ็กเก็ตฟิลเตอร์ริงสเตตฟูลไฟร์วอลล์ แล้วก็ทำเช่นเดียวกันกับแพ็กเก็ตฟิลเตอร์ แต่จะบันทึกข้อมูลเกี่ยวกับการเชื่อมต่อ ที่เกิดขึ้นลงในตารางการเชื่อมต่อ ก่อนที่จะส่งแพ็กเก็ตนั้นไปยัง ไอพีสแต็ก (IP stack) ตัวตารางนี้จะมีส่วนสำหรับบันทึกข้อมูลสำหรับแต่ละการเชื่อมต่อที่ต้องการ โดยปกติจะเก็บข้อมูล source and destination address , protocol, port, flag แต่มีไฟร์วอลล์บางยี่ห้อที่เก็บข้อมูล sequence number เพิ่มด้วย เพื่อใช้ในการตรวจสอบแพ็กเก็ตที่กำลังจะเข้ามาและป้องกันการทำ session hijacking

Src_IP	Src_Prt	Dst_IP	Dst_Prt	IP_prot	Type	Flags
191.168.7.131	10003	207.229.143.8	25	6	16385	02ffff00
191.168.7.131	10003	207.229.143.8	24	6	16385	02ffff00

ตารางที่ 4-2 ตัวอย่าง State table

เมื่อแพ็กเก็ตไฟเตอร์ริงไฟร์วอลล์ ได้รับแพ็กเก็ตมันจะตรวจสอบข้อมูลกับตารางการเชื่อมต่อว่าเป็นส่วนของการเชื่อมต่อที่สร้างไว้แล้วหรือไม่ โดยจะพิจารณาจากข้อมูล source address, destination address , source port , destination port จะต้องสอดคล้องกับตารางการเชื่อมต่อ ซึ่งถ้าเป็นส่วนหนึ่งของการเชื่อมต่อจริงก็ไม่มีควมจำเป็นใดๆที่ต้องตรวจสอบซ้ำอีก แต่ในไฟร์วอลล์บางยี่ห้อ นั้น จะพิจารณา sequence number ของแพ็กเก็ตเพิ่มเติมด้วย เช่น CiscoPIX ในขณะที่ Checkpoint's Firewall-1 ไม่พิจารณา sequence number แต่อย่างใด และเนื่องจากการเก็บ history ไว้ในตารางการเชื่อมต่อ ดังนั้นสเตตฟูลไฟร์วอลล์สามารถรีเฟรชแพ็กเก็ตที่ผิดปกติได้ และถ้าแพ็กเก็ตที่ส่งมาเป็นส่วนหนึ่งของการเชื่อมต่อที่สร้างไว้แล้วก็สามารถส่งผ่านได้เลย ซึ่งทำให้ประหยัดเวลาในการตรวจสอบจากไฟร์วอลล์ใหม่อีกรอบ

ถ้าแพ็กเก็ตที่ส่งมาไม่ตรงกับการเชื่อมต่อที่สร้างไว้แล้ว และไม่ใช่ SYN แพ็กเก็ต ตัวแพ็กเก็ตนั้นก็จะถูกดรอปรทิ้งไป และแม้แต่แพ็กเก็ตที่ผสมแฟล็กแปลกๆ เช่น SYN/FIN (เป็นกระบวนการหนึ่งในการทำพอร์ตสแกนนิ่ง) ก็จะถูกดรอปรไปเช่นเดียวกัน ทั้งนี้ไฟร์วอลล์ส่วนใหญ่สามารถบันทึกล็อกไฟล์ได้ด้วย ซึ่งขึ้นอยู่กับที่ตั้งค่าของผู้ดูแลระบบเองว่าต้องการเก็บข้อมูลใด

ในกรณีที่การส่ง ACK แพ็กเก็ตดังกล่าวถูกส่งมาโดยเจตนาร้าย เพราะเมื่อเครื่องปลายทางได้รับ ACK มักจะส่งสัญญาณ RST กลับไป ซึ่งจะแสดงให้เห็นว่าเครื่องปลายทางนั้นยังเปิดอยู่ และเปิดให้บริการในพอร์ตดังกล่าว (destination port ที่ถูกส่งมาพร้อมกับ ACK packet) บางครั้งยังสามารถใช้ตรวจสอบระบบปฏิบัติการของเครื่องปลายทางได้อีกด้วย (OS fingerprint) เพราะระบบปฏิบัติการในแต่ละระบบนั้นมักมีวิธีตอบกลับที่ไม่เหมือนกัน